

Threat Mitigation through Asset Management

Risk Analysis and Mitigation Strategies

Security Assessment — TechStart Solutions (fictional scenario)

Prepared by	Marco Helie	Scope	12 assets / 7 threat scenarios
Document	Risk assessment & mitigation plan	Frameworks	NIST IR lifecycle, risk matrix scoring
Version	1.1 — December 2025	Environment	Small office, 10 employees

Executive Summary

This assessment documents the asset inventory, risk analysis and mitigation planning for TechStart Solutions, a ten-person software consulting firm operating from a single office with a mixed remote and in-office workforce. Twelve assets were catalogued and classified by criticality, and seven threat scenarios were evaluated using a likelihood × impact scoring model.

Two risks were rated critical (score 12): ransomware delivered through phishing against the file server and workstations, and unauthorized access arising from weak or default credentials with no multi-factor authentication. Together these account for the majority of realistic loss exposure in this environment, and both are addressable with low-cost controls.

The primary recommendation is to prioritise credential hardening and backup integrity before any further investment in perimeter tooling: MFA on administrative interfaces, unique credentials via a password manager, and restore capability verified by monthly test restores. Secondary priorities are IoT network isolation and file access logging to close the detection gap around insider activity. Each threat below is paired with both preventive and detective controls, and the assessment closes with a six-phase incident response plan aligned to the NIST incident handling lifecycle.

Findings Summary

#	Threat Scenario	Primary Target	L	I	Score	Priority
1	Ransomware attack	File server, workstations	3	4	12	Critical
2	Unauthorized access — weak passwords	Router, file server, workstations	3	4	12	Critical
3	IoT device compromise	Smart devices	3	3	9	Medium
5	Wi-Fi eavesdropping	Wireless access point	2	4	8	Medium
6	Insider threat / data exfiltration	File server, workstations	2	4	8	Medium
4	Data theft via printer	Multifunction printer	2	3	6	Low
7	Physical theft	Workstations, NAS	2	3	6	Low

L = likelihood (1–5), I = impact (1–5). Score = likelihood × impact. Rows are ordered by score, not by threat number.

1. Scope and Methodology

TechStart Solutions is a fictional ten-person software and consulting firm used here as a realistic small-business scenario. The environment consists of a single office location, a mix of remote and on-site staff, and basic IT infrastructure with no dedicated security team.

The assessment was carried out in three phases:

- **Asset management** — identify every device on the network, record its addressing, operating system, purpose and connectivity, and classify it by criticality.
- **Risk analysis** — identify credible threats against those assets, score each on likelihood and impact, and plot the results on a risk matrix to establish priority.
- **Mitigation planning** — define preventive and detective controls for each threat, then document an incident response plan for the residual risk that controls do not eliminate.

Risk scores use a five-point scale for both likelihood and impact, multiplied to produce a score from 1 to 25. Scores of 10 and above are treated as critical, 7–9 as medium, and 6 or below as low. Every threat receives both a preventive control (reduce likelihood) and a detective control (reduce time to discovery), on the assumption that prevention will eventually fail.

2. Asset Inventory

Twelve assets were identified and grouped into three criticality tiers.

2.1 Critical Assets

Asset	Address / OS	Purpose	Security Requirements
Router / Firewall	192.168.1.1 pfSense 2.7	Internet gateway, firewall, DHCP	Strong admin credentials, firmware updates, firewall rules, VPN
File Server (NAS)	192.168.1.10 TrueNAS Core	Centralised file storage, project files, backups	Encrypted storage, ACLs, regular backups, authentication
Wireless AP	192.168.1.2 Custom firmware	Wireless connectivity for office devices	WPA3, MAC filtering, guest network isolation

2.2 Sensitive Assets

Asset	Address / OS	Purpose	Security Requirements
Workstations (x4)	192.168.1.20–23 Windows 11 Pro / macOS 14	Daily work, email, development	Full disk encryption, antivirus, host firewall, screen lock, patching
Printer / Scanner	192.168.1.30 Embedded firmware v3.2	Document printing and scanning	Secure print release, admin password, firmware updates

2.3 Non-Critical Assets

Asset	Address	Purpose	Security Requirements
IoT devices (x3)	192.168.1.40–42	Smart thermostat, security camera, smart speaker	Separate guest network, default passwords changed
Guest laptop / tablet	DHCP, 192.168.2.x	Loaner device for visitors, internet only	Network isolation, no access to internal resources

3. Risk Analysis

Seven threat scenarios were identified against the inventoried assets. Each was scored on likelihood and impact, with the underlying vulnerability recorded so that mitigation could be targeted at the cause rather than the symptom.

Threat 1 — Ransomware Attack

Target File server, workstations	Vulnerability Employees clicking phishing emails; unpatched systems	Likelihood Medium (3)	Impact High (4)	Score 12
--	---	---------------------------------	---------------------------	---------------------------

Threat 2 — Unauthorized Access via Weak Passwords

Target Router, file server, workstations	Vulnerability Weak or default passwords; no MFA	Likelihood Medium (3)	Impact High (4)	Score 12
--	---	---------------------------------	---------------------------	---------------------------

Threat 3 — IoT Device Compromise

Target Smart thermostat, camera, speaker	Vulnerability Outdated firmware; weak vendor security posture	Likelihood Medium (3)	Impact Medium (3)	Score 9
--	---	---------------------------------	-----------------------------	--------------------------

Threat 5 — Wi-Fi Eavesdropping

Target Wireless access point	Vulnerability Weak encryption or shared credentials	Likelihood Low (2)	Impact High (4)	Score 8
--	---	------------------------------	---------------------------	--------------------------

Threat 6 — Insider Threat / Data Exfiltration

Target File server, workstations	Vulnerability No access logging; shared credentials	Likelihood Low (2)	Impact High (4)	Score 8
--	---	------------------------------	---------------------------	--------------------------

Threat 4 — Data Theft via Printer

Target Multifunction printer	Vulnerability Unencrypted print jobs; documents retained on device	Likelihood Low (2)	Impact Medium (3)	Score 6
--	--	------------------------------	-----------------------------	--------------------------

Threat 7 — Physical Theft

Target Workstations, NAS	Vulnerability Lack of physical security measures	Likelihood Low (2)	Impact Medium (3)	Score 6
------------------------------------	--	------------------------------	-----------------------------	--------------------------

3.1 Risk Matrix

Threats plotted by likelihood against impact. The upper-right quadrant carries the highest priority.

Likelihood ↓ / Impact →	Low (1–2)	Medium (3)	High (4–5)
High (4–5)	—	—	—
Medium (3)	—	Threat 3 (9)	Threat 1 (12) Threat 2 (12)
Low (1–2)	—	Threat 4 (6) Threat 7 (6)	Threat 5 (8) Threat 6 (8)

Cell shading indicates priority band: red = critical, amber = medium, grey = low.

4. Mitigation Strategies

Each threat is addressed with two classes of control. **Preventive** controls reduce the likelihood of the threat succeeding. **Detective** controls reduce the time between compromise and discovery, which is what limits damage once prevention fails.

Threat 1 — Ransomware

Preventive

- Implement email filtering with anti-phishing protection
- Enable automatic updates on all systems
- Deploy and maintain endpoint protection across all workstations
- Deliver quarterly phishing recognition training to all staff
- Apply application whitelisting on critical systems

Detective

- Monitor the network for unusual file encryption activity
- Verify backups monthly through test restores, not status checks alone
- Alert on anomalous outbound traffic patterns

Threat 2 — Weak Passwords / Unauthorized Access

Preventive

- Enforce a password policy of 12+ characters with complexity requirements
- Require MFA on router administration, file server and workstations
- Issue unique credentials for every administrative account via a password manager
- Disable unnecessary administrative accounts
- Apply account lockout after repeated failed logins

Detective

- Enable and review authentication logs weekly
- Alert on repeated failed authentication attempts
- Audit user access permissions quarterly

Threat 3 — IoT Compromise

Preventive

- Isolate all IoT devices on a separate VLAN or guest network
- Change every default credential on deployment
- Disable unused features, particularly vendor remote access
- Update IoT firmware quarterly

Detective

- Monitor IoT network traffic for behavioural anomalies
- Alert on unexpected outbound connections from IoT devices

Threat 5 — Wi-Fi Eavesdropping

Preventive

- Use WPA3 encryption (WPA2 as the absolute minimum)
- Enforce a strong pre-shared key of 20+ characters
- Maintain a separate guest network with no route to internal resources
- Disable WPS

Detective

- Review connected devices weekly
- Inspect DHCP logs for unrecognised devices

Threat 6 — Insider Threat

Preventive

- Implement least-privilege access so users reach only what their role requires
- Require individual accounts; prohibit credential sharing
- Enforce authentication on all file server access
- Enable file versioning and snapshots

Detective

- Enable file access logging
- Review large file transfers and bulk deletions
- Audit permissions quarterly

Threat 4 — Printer Data Theft

Preventive

- Enable secure print release requiring a PIN at the device
- Keep printer firmware current
- Disable internal document storage where the device supports it
- Change the default administrative password

Detective

- Review printer access logs monthly

Threat 7 — Physical Theft

Preventive

- Enable full disk encryption on all workstations and the NAS
- Fit cable locks to desktop equipment
- Lock the server and equipment closet
- Maintain a visitor sign-in process

Detective

- Retain camera footage for review if equipment goes missing

5. Incident Response Plan

Controls reduce risk but do not eliminate it. The following six-phase plan aligns to the NIST incident handling lifecycle and defines what happens when an incident occurs despite the mitigations above.

Phase 1 — Identification

- Employees report suspicious activity to the IT lead
- Automated alerts from endpoint protection and firewall
- Weekly log reviews surface anomalies not caught in real time
- Unusual system behaviour reported by users (degraded performance, unexpected prompts)

Phase 2 — Containment

- **Immediate:** disconnect the affected device from the network; preserve evidence by leaving the system powered on where possible; reset credentials for affected accounts; block malicious addresses at the firewall
- **Short-term:** isolate the affected network segment if multiple devices are involved; disable compromised accounts; brief the team on indicators to watch for

Phase 3 — Eradication

- Run full anti-malware scans on affected systems
- Remove malicious files and software
- Patch the vulnerabilities that permitted the intrusion
- Rebuild from a known-clean backup where integrity cannot be assured
- Reset all credentials that may have been exposed
- Update firewall rules to close the attack vector

Phase 4 — Recovery

- Restore data from verified clean backups
- Reconnect systems progressively under monitoring
- Verify functionality and confirm no residual indicators remain
- Maintain heightened monitoring for 72 hours after recovery

Phase 5 — Communication

- **Internal:** IT lead notifies management within one hour of a confirmed incident
- **Staff:** email all employees describing the nature of the incident and any required action such as password resets
- **External:** notify clients within 24 hours where their data may have been affected
- **Regulatory:** report to the relevant authority where the data type requires it

Phase 6 — Post-Incident Activity

- Document the full incident timeline and every response action taken
- Update mitigation strategies based on what the incident revealed
- Deliver additional training where human error was a contributing factor
- Review and revise this response plan
- Hold a 30-day follow-up to verify all corrective actions are in place

6. Conclusion and Recommended Sequence

The risk profile of this environment is dominated by two credential- and human-driven scenarios rather than by sophisticated technical attack. That is typical of organisations at this size, and it is encouraging: the controls that address the critical findings are inexpensive and can be implemented without specialist tooling.

Recommended order of implementation:

- **Immediate** — deploy MFA on all administrative interfaces and the file server; roll out a password manager and eliminate shared credentials.
- **Within 30 days** — verify backup restore capability through a live test; enable email filtering and schedule the first phishing awareness session.
- **Within 90 days** — move IoT devices to an isolated VLAN; enable file access logging on the NAS to close the insider detection gap.
- **Ongoing** — quarterly permission audits, quarterly firmware updates, and monthly backup restore tests.

The most significant gap identified is not a missing control but a missing capability: there is currently no logging that would reveal insider data movement, and no verification that backups are actually restorable. Both are addressed above and both should precede any further spending on preventive tooling.